

Firewall Security Guidelines

October 2023

CHANGE HISTORY

Version	Date	Summary of changes	Author
0.1	18 Oct 2023	Initial draft	Rama Sagi
0.2	19 Oct 2023	Document layout, forward statement, formatting and minor content edits. F	Darron Richardson

APPROVALS

Version	Approval Date	Approver	Reason for changes
1.0	Oct 2023	Senior Manager, Cyber Security	Initial document

Contents

CHANGE HISTORY	2
APPROVALS.....	2
1. Forward	4
2. General Firewall Guidelines	5
3. Firewall Administration	5
4. Firewall Rules.....	6
4.1 Server Network Production Firewall Operation Rules.....	6
4.2 Server Network Development Operation Rules.....	6
4.3 Border Firewall Operation Rules	7
4.4 Other Firewalls Including Host Based	7
5. Best Practices for Firewall Rule Configuration.....	7
6. Establishing a Firewall Configuration Change Procedure.....	8
7. Documenting Firewall Rules	8
8. Physical Access & Environment	8
9. Logical Access & Remote Administration	9
10. System Backup.....	9
11. Upgrade And Patches	9
12. Logs And Audit Trails.....	9
13. Documentation	10
14. Encrypted Channels Over Public/Entrusted Network	10
15. Enforcement	10
16. Injecting firewall logs into a SIEM	11
17. Automated blocking	11
18. Generic Firewall Audit Checklist.....	12
19. Firewall Audit Checklist - Security Elements:	13
20. Reporting Firewall Specific Incidents.....	16
21. Reporting Firewall Specific Incidents.....	16
References	17

1. Forward

Firewalls are the first line of defense against cyber threats, and having well-defined guidelines in place is essential for safeguarding the Southern Cross University's (SCU) network infrastructure and sensitive data. These guidelines will establish a consistent and robust security posture across the organisation, ensuring that all employees, departments, and systems are working together to maintain a secure digital environment.

Key objectives and benefits of these Firewall Guidelines include:

1. **Enhanced Security:** By strictly adhering to these guidelines, we will significantly reduce the risk of unauthorised access, data breaches, and cyberattacks on our network.
2. **Standardisation:** These guidelines provide a standardised approach to firewall configuration, management, and monitoring, ensuring a consistent level of security across all systems.
3. **Compliance:** Our guidelines are designed to align with relevant industry regulations and compliance standards, helping us meet legal requirements and maintain a strong security posture.
4. **Incident Response:** The guidelines include procedures for handling and responding to firewall-related incidents, minimising downtime and data loss in case of security breaches.
5. **Employee Training:** We will provide training and awareness programs to ensure that all employees are well-versed in these guidelines, fostering a security-conscious culture.
6. **Continuous Improvement:** We will establish regular review and update processes to adapt to evolving threats and technology, ensuring our guidelines remain effective over time.

Technical Services members who are engaged in the implementation, configuration, management or use of Firewall are encouraged to familiarise themselves with these guidelines and actively participate in their implementation. Our collective commitment to these guidelines will play a pivotal role in securing SCU's digital infrastructure and preserving the trust of our stakeholders.

The Firewall Guidelines will be available for review and reference and the Cyber Security team will be available to address any questions or concerns that may arise during the adoption of these guidelines and associated rule sets.

2. General Firewall Guidelines

- The firewall software should run only on dedicated computer system. Except for the firewall-related utilities or its safeguarding components (e.g., Intrusion Detection System), no other non-firewall related software should co-exist/installed in the firewall system.
- Restricted policy shall be enforced in the firewall such that all services are denied unless specifically permitted.
- If a different users/network community requires different firewall policies, network segregation should be in place to isolate the more permissive users/network on a subnet apart from the more securely protected network. All access from the said subnet should comply with the established firewall policy and guidelines.
- Details of the internal trusted network should not be visible from the entrusted network side of the firewall.
- Arrangement should be made (whether system-automated or through manual detection) to promptly notify the Firewall Administrator(s), the Backup Firewall Administrator(s), Manager, Infrastructure Provisioning and escalated to the Senior Manager, Cyber Security ¹ of any intrusion or break-down in the firewall system.
- Deployment of firewalls should comply with the established Network Trust Model and the recommended firewall-layers required.
- For gateway connection to the Internet, consideration should be given at management's discretion, to deploy two-tiered hybrid-platform firewalls.
- For any systems hosting critical applications, or providing access to critical information, internal firewalls or filtering routers should be used to provide access control and support for auditing and logging. These controls should be used to segment the internal network to support the access policies developed by the designated owners on information.
- All hosts (servers) protected behind a firewall should be segmented through physical-ports at the firewall and not through logical-segmentation via a VLAN-switch, for example.
- The connection of any new devices to a production environment should take in to consideration best practices from [Centre for Internet Security \(CIS\) Benchmarks](#).

3. Firewall Administration

- There should be authorisation by users, application-systems owners and the Manager, Infrastructure Provisioning for any request for connections and rules/services definition on the firewall. Prior to authorisation, all such request should be first reviewed, and the acceptable security controls established by the Cyber Security team.
- Designated Firewall Administrator(s) and Backup Firewall Administrator(s) should administer the firewall.
- Any modification on the firewall shall be under the charge of the Firewall Administrator(s) or Backup Firewall Administrator(s) and requires approval from IT Security.
- The Firewall Administrator(s) should validate on periodic basis (e.g., quarterly) with application-systems/hosts owners all previously defined connections and allowed rules and services in the firewall. Such definitions, when no longer valid, should be confirmed by the application-systems/hosts owners and promptly removed by the Firewall Administrator(s).
- There should be authorisation by users, application-systems owners, and the Manager, Infrastructure Provisioning for any request for connections and rules/services definition on

the firewall. Prior to authorisation, all such request should be first reviewed, and the acceptable security controls established by the Cyber Security team.

4. Firewall Rules

4.1 Server Network Production Firewall Operation Rules

- All network firewalls will have a default deny mantra.
- All servers providing services to directly to the Internet must be located in Presentation (External) zone.
- Firewall rules must be in place and will govern the communication allowed into each tier and between the tiers.
- Firewall rules are to be minimum required to deliver business needs — following a least privileged model.
- All administrative and management access which is required to servers within the corporate and development silo will be provided by the Management VPN solution.
- All Backup and Monitoring will be provided through the management network.
- IPs are to be issued by the Network Team, according to the IP allocation process. Change of Tier/Silo will require an IP change.
- Standard firewall change process should be carried out to minimise impact on environment and to allow for backout or recovery if required.
- Changes for BAU group assignment (e.g., Finance access) will be performed on an ad hoc basis.
- Additional changes are possible and should be included as part of the normal change management processes sent for CAB review (include firewall rules with system/service deployment changes noting any pre-arranged Cyber Security team's agreement or disagreement).
- Where direct communication with other networks is not viable, a connection via proxy where viable is preferred over a NAT approach.

4.2 Server Network Development Operation Rules

- All network firewalls will have a default deny mantra.
- All hosts will be issued with private IP addresses.
- All servers providing services to directly to the Internet must be located in Presentation (External) zone.
 - Policy based NAT will be created to allow for external communication.
 - Preference will be for the NAT configuration to be enabled and disabled based on work being carried out. This is not mandatory.
 - Additional scrutiny for requests where a NAT rule will need to be established will be carried out.
- Firewall rules must be in place and will govern the communication allowed into each tier and between the tiers.
- Communication directly with production systems is to be discouraged. However, exceptions can — and will — be made where it is not possible or appropriate to have a completely isolated development environment.
- All administrative and management access which is required to servers within the corporate and development silo will be provided by the Management VPN solution.
- All Backup and Monitoring will be provided through the management network.
- All data transfers (e.g., production to development) must be performed through intermediary hosts within the management network (providing an "air gap" between prod and dev).
- IPs are to be issued and documented by the Network Team, according to the IP allocation process. Change of Tier/Silo will require an IP change.
- With the exception of communication to the wider internet and production silos, firewall changes can be performed ad-hoc and without in-depth scrutiny.

- Where direct communication with other networks is not viable, a connection via proxy where viable is preferred over a NAT approach.

4.3 Border Firewall Operation Rules

- Default denies ingress traffic.
- Allowing connections direct to client networks is expressly forbidden.
- Dangerous or historically abused ports and services will be blocked where practical.
- Where practical user traffic will be proxied to provide further security to the user network.
- Legacy Servers cannot request firewall changes and must migrate to the Server Network.
- No new servers can be deployed into the legacy network.

4.4 Other Firewalls Including Host Based

- Default denies ingress and egress traffic.
- Rules allowing traffic must follow principle of least privilege.
- Rules should limit access to defined expected users or services (e.g., VU Internal or DNS servers).
- Rules allowing administrative access should be limited as much as possible.

5. Best Practices for Firewall Rule Configuration

When configuring firewall rules, it is paramount to consider potential security risks in order to ensure a robust and reliable network Defence. Security is a multifaceted field, and the principles outlined in this article pertain specifically to the establishment of perimeter firewall rules.

- **Avoiding Broad Definitions:** Allowing a rule that permits "IP ANY ANY" – thereby allowing all traffic on any port from any source to any destination – is a hazardous practice. It goes against established security concepts, such as the principle of least privilege. In general, it is essential to specify the destination port, and when necessary, the destination IP address. The source IP address should also be specified, unless the application is designed to accept clients from the internet, like a web server. A sound guideline is to allow TCP traffic on specific ports like 80 (HTTP) for a web server.
- **Specific Rule for Web Servers:** Configuring a rule that permits "IP to ANY WEB SERVER" – allowing all traffic to a web server from any source – is not recommended. It is prudent to allow only specific ports like 80 (HTTP) and 443 (HTTPS) for a web server. "Allow ANY WEB-SERVER HTTP" is a good rule of thumb to follow.
- **Restricting RDP Access:** Allowing "TCP ANY WEB-SERVER 3389" to permit RDP access to a web server from any source is a risky practice. It is crucial to clearly define who has access to server administration. A more secure approach is to allow RDP only from the administrator's specific IP address on the internet. "Allow TCP IP 3389 WEB-SERVER" serves as a basic guideline.
- **Securing Database Access:** Permitting "TCP ANY DB-SERVER 3306" for MySQL to connect to the database from any location is not advisable. Exposing a database server to the entire internet is a significant security risk. If database queries must traverse the public internet, it's

best to specify the complete source IP address. A safer practice is to enable database traffic over the internet through a VPN and not in plain text.

6. Establishing a Firewall Configuration Change Procedure

Before embarking on any changes to your firewall rules, it's crucial to have a well-defined change management process in place. This process ensures that changes are implemented smoothly and securely. The following steps can be included in a standard change procedure:

1. **Change Request Method:** Create a formal method for business users to request firewall configuration changes.
2. **Evaluation Process:** The firewall team should conduct a thorough risk analysis to determine the best course of action, balancing the needs of business users with security requirements.
3. **Rule Modification Validation:** Develop a procedure to ensure that any modifications to firewall rules yield the intended results.
4. **Deployment Process:** Implement a controlled deployment process, including testing, to move new rules into production.
5. **Verification Process:** Establish a process for verifying that new firewall settings are working as intended post-implementation.
6. **Change Tracking System:** Implement a system to record and track all changes made to the firewall rules for future reference and auditing purposes.

7. Documenting Firewall Rules

A comprehensive and well-maintained documentation of firewall rules is crucial for effective network security management. Your documentation should enable any member of your network security team to swiftly comprehend the purpose and function of each firewall rule. At a minimum, the following information should be recorded:

- **Purpose of Firewall Rule:** A clear description of the rule's intended purpose.
- **Services Affected:** Specify the services impacted by the rule.
- **Affected Users and Devices:** Identify the users and devices affected by the rule.
- **Rule Creation Date:** Record the date when the rule was added or modified.
- **Rule Expiry Date (if applicable):** If the rule is temporary, document the date when it is set to expire.
- **Rule Creator's Name:** Identify the individual responsible for creating or modifying the rules

8. Physical Access & Environment

- The firewall should be in restricted access area where access is allowed on a need to basis.
- The firewall should be installed in a controlled environment appropriate for 24x7 computer operations, with air-conditioning, and uninterruptible power supply.

9. Logical Access & Remote Administration

- Logical access to the firewall should be restricted only to the Firewall Administrator(s), Backup Firewall Administrator(s) and the Manager, Infrastructure Provisioning. Any other access granted should be on a need to basis and with prior approval.
- The Manager, Infrastructure Provisioning shall approve all access and privilege-level attributes.
- Access previously granted which is invalid or no longer required should be removed immediately.
- Logical access to the firewall, through administration workstation or direct terminal, should be controlled with authentication, with for example with user id and password.
- Remote connection for firewall administration should only be considered if operational environment requires. If via entrusted network, remote connection should be secured with session encryption.

10. System Backup

The following files in the firewall must be periodically backed up for recovery in case of system failure or for forensic-related activity in case of incidents: -

- 1) System Configuration
 - a. Firewall software (e.g., Rules/Policies, Network objects, definitions, etc)
 - b. Operating system (e.g., inetd.conf, rc3.d)
 - c. Network definitions (e.g., routing tables, hostname)
- 2) Logs
 - a. Firewall software (e.g. fwlog, etc)
 - b. Operating system (e.g. syslog, etc)
- 3) Removable media when used to back up the above files should be labelled and securely stored.

11. Upgrade And Patches

- Patches (including critical security updates) provided by a firewall vendor should be promptly implemented with CAB approval.
- The Firewall Administrator shall evaluate new version or release of the firewall or its platform capacity requirement to determine if upgrading is necessary. Prior approval from the Manager, Infrastructure Provisioning should be obtained before implementation.
- After any upgrade, the firewall's proper operation shall be verified prior to going operational.

12. Logs And Audit Trails

- Where available in the firewall system, the following logging should be enabled: -
 - The firewall's filtering activity (e.g., TCP connect attempts, in-bound and out-bound proxy traffic information, etc)
 - The firewall's audit trail (e.g., login/logout activity, connect time, rules/definition changes etc.)
 - At the firewall's system level (e.g., disk media errors, configuration/parameter changes, etc).

- Depending on operational requirement OR business criticality environment, the Senior Manager, Cyber Security should establish if the logs (in total or selectively) be reviewed: -
 - On a periodic basis (*from standpoint of accountability or for detective control purpose*) OR
 - On situational required basis (*for problem determination or for forensic investigative purpose*).
- For the review of the logs, where accountability over firewall administration is concerned, it should be carried out internally either by the Cyber Security team, auditors or an independent party.
- The logs should be archived for an established period.
- At the end of archival, the logs should be dispensed with securely, either through total irrecoverable erasure or by overwriting its data.

13. Documentation

- All operational procedures for the firewall should be documented. At the minimum, they consist of the following: -
 - Administration procedures
 - Backup procedures
 - Troubleshooting guide
 - Review of firewall logs and audit trails
 - Housekeeping procedures
- The firewall's configurable parameters should be documented and kept in confidence, accessible only by Firewall Administrator(s), Backup Firewall Administrator(s) and the Manager, Infrastructure Provisioning. At the minimum, the configuration documents should include:
 - Network diagram(s)
- IP addresses of all relevant network devices, internal hosts and relevant hosts of the Internet Service Provider (ISP) e.g., DNS server, router, etc
 - Routing tables
 - Firewall rules
- All the above documentation should be updated following any changes to the firewall.

14. Encrypted Channels Over Public/Entrusted Network

- Any connection between internal host to an external organisation's host over the public network or entrusted network for business-related exchange (e.g., B2B) shall use encrypted channel such as Virtual Private Network (VPN), router-to-router encryption, Secured-Socket-Layer (SSL), Secure-Shell (SSH), etc to ensure privacy and integrity of its data communication.
- For establishing encrypted channel, there should be secured means for distributing the encryption keys prior to its operational use.

15. Enforcement

- All staffs are required to comply with this security policy and its appendices. Appropriate action may be taken against any staff who fail to comply with the Organisation's security policies or circumvent/violate any security systems and/or protection mechanisms.
- Staff having knowledge of personal misuse or malpractice of IT Systems must report immediately to management and IT Security.

- Organisation staff must ensure that the Organisation's contractors and others parties authorised by the Organisation using its internal computer systems, adhere with these guidelines.
- Where the role of the service provider is outsourced to a vendor, the outsourced vendor should ensure compliance with this policy.

16. Injecting firewall logs into a SIEM

It's essential to implement firewall log integration with Technology Services chosen Security information and event management (SIEM) tool. Suggesting the following best practices:

- Ensure that the firewall logs are properly formatted and that the SIEM can ingest them. Compatibility is crucial.
- Define clear use cases and alerting rules to avoid overwhelming security teams with false positives.
- Regularly review and update the integration to adapt to evolving threats and changes in the network environment.
- Consider the volume of logs generated by the firewall, as this can affect SIEM performance and storage requirements.
- Encrypt and secure the transmission of log data between the firewall and the SIEM to prevent data tampering.

17. Automated blocking

Automated blocking of known threats in a firewall by integrating data from trusted platforms is a common and effective security practice. This process often involves leveraging threat intelligence feeds and threat intelligence sharing platforms to keep our firewall up-to-date on the latest threats and automatically block malicious traffic. Here's how it works:

1. **Threat Intelligence Feeds:** Security organisations and trusted platforms, such as threat intelligence providers, cybersecurity vendors, government agencies, and industry-specific Information Sharing and Analysis Centers (ISACs), compile and distribute lists of known threats, including IP addresses, domain names, and file hashes associated with malicious activities.
2. **Integration with Firewall:** Firewalls can be configured to receive and regularly update threat intelligence feeds from these trusted sources. The integration can be done using various protocols, such as STIX/TAXII or custom API integrations.
3. **Automated Blocking:** Once the firewall receives threat intelligence data, it can automatically update its rules to block traffic from or to the malicious entities listed in the threat intelligence feeds. This automation can apply to various aspects, such as blocking connections to malicious IP addresses, denying access to known malicious domains, or preventing the download of files with known malicious hashes.

Benefits of Automated Blocking:

- **Real-Time Protection:** Automated blocking enables real-time protection against known threats. As soon as a threat is identified and shared on trusted platforms, your firewall can react to block it without manual intervention.
- **Reduced Attack Surface:** By blocking known malicious entities, your attack surface is reduced, making it more challenging for cybercriminals to infiltrate your network.
- **Operational Efficiency:** Automating the process of blocking known threats saves time and resources that would otherwise be spent on manual rule creation and updates.
- **Comprehensive Defence:** Integrating threat intelligence feeds from multiple trusted platforms allows you to benefit from a broader range of threat information, increasing your Defence's effectiveness.

Considerations and Best Practices:

- **Quality of Threat Intelligence:** Ensure that the threat intelligence feeds you integrate are reliable and regularly updated. Accuracy and freshness are critical.
- **Fine-Tuning Rules:** While automated blocking is effective, it's important to fine-tune rules to minimise false positives, which can disrupt legitimate traffic.
- **Logging and Monitoring:** Continue to log and monitor the activity of your firewall, even with automated blocking in place. This allows you to review and investigate any blocked traffic and adjust your rules as needed.
- **Redundancy:** Implement redundant systems and failover mechanisms to ensure that your firewall remains functional even if there are issues with threat intelligence feeds or the automation process.

18. Generic Firewall Audit Checklist

Before proceeding with the firewall audit, consider the following factors:

- **Operating System:** This checklist focuses on firewall software and doesn't address the security aspects of the underlying operating system.
- **Port Restrictions:** Verify that ports to be restricted align with the business's actual needs. Recommend alternate security measures if services associated with specific ports are required.
- **Application-Level Firewalls:** Ensure the underlying operating system is secure before evaluating the application-level firewall's security.
- **Defence in Depth:** Assess the security of other components, such as IDS, operating systems, web applications, routers, and databases. For firewall network appliances, review the firewall configuration.
- **Rulesets:** Customise the rulesets based on organisational requirements, but include essential rules for blocking private addresses, illegal addresses, unroutable addresses, etc.
- **Laptop Users:** Evaluate laptop usage and ensure personal firewalls are installed on these devices to mitigate risks associated with remote access.

19. Firewall Audit Checklist - Security Elements:

1. **Ruleset Order:** Review and ensure that rulesets are ordered as follows:

- ☐ Anti-spoofing filters
- ☐ User permit rules
- ☐ Management permit rules
- ☐ Noise drops
- ☐ Deny and Alert
- ☐ Deny and log

2. **Application-Based Firewall:**

- ☐ Monitor security policy violations using audit logs.
- ☐ Consider integrating application-level firewall logs with intrusion detection systems.
- ☐ Keep application-level firewall vulnerabilities and attack signatures up to date from trusted sources.
- ☐ Block specific commands for SMTP and FTP.
- ☐ Review and update denied URLs.

3. **Stateful Inspection:**

- ☐ Review state tables for source, destination IPs, source/destination ports, and timeouts.
- ☐ Ensure appropriate timeouts are set.
- ☐ Implement traffic filtering for scripts, ActiveX, and Java.
- ☐ Review MAC address filters for compliance with the security policy.

4. **Logging:**

- ☐ Verify that logging is enabled.
- ☐ Regularly review logs for potential attack patterns.

5. **Patches and Updates:**

- ☐ Test and install the latest firewall product patches and updates.
- ☐ Ensure updates are obtained from trusted sources.

6. **DMZ (Demilitarised Zone):**

- ☐ Use two different firewall types with dual NICs for added security.
- ☐ Customise rulesets for each firewall based on location.

7. Vulnerability Assessments/Testing:

- ☐ Conduct tests for open ports using tools like nmap.
- ☐ Test rulesets after changes to avoid creating vulnerabilities.

8. Compliance with Security Policy:

- ☐ Ensure rulesets align with the organisation's security policy.

9. Block Spoofed, Private, and Illegal Addresses:

- ☐ Block standard unrouteable, private (RFC 1918) addresses, reserved addresses, and illegal addresses.

10. Block and Log Loose/Strict Source Routing:

- ☐ Block and log loose source routing and strict source routing.

11. Remote Access:

- ☐ Use SSH (port 22) for remote access instead of Telnet.

12. File Transfers:

- ☐ Isolate FTP servers in a separate subnet from the internal network.

13. Mail Traffic:

- ☐ Determine the mail protocol in use and set rules to block incoming mail traffic, except to internal mail servers.

14. ICMP (ICMP 8, 11, 3):

- ☐ Block ICMP echo requests and replies.
- ☐ Block outgoing time exceeded and unreachable messages.

15. IP Readdressing/IP Masquerading:

- ☐ Enable readdressing to hide internal IP addresses from external networks.

16. Zone Transfers:

- ☐ Implement packet filtering for UDP/TCP 53.
- ☐ Restrict IP packets from the Internet to authorised replies from the internal DNS server.
- ☐ Prevent unauthorised zone transfers.

17. Egress Filtering:

- ☐ Allow only traffic originating from internal network IPs.

- ☐ Log any traffic from IPs outside the internal network.

18. Critical Servers:

- ☐ Implement deny rules for traffic destined for critical internal addresses from external sources, based on organisational requirements.

19. Personal Firewalls:

- ☐ Train laptop users on the use of personal firewalls.
- ☐ Review personal firewall settings for access restrictions, attack protection, logging, and alerts.
- ☐ Establish a process for updating the software.

20. Distributed Firewalls:

- ☐ Distribute security policies to all hosts, ensuring policy integrity during transfer.
- ☐ Use encryption (e.g., IPSec) to secure policy transfers.
- ☐ Authenticate hosts using cryptographic certificates.

21. Stealth Firewalls:

- ☐ Reset default users and passwords.
- ☐ Configure firewall access control lists for appropriate traffic routing.
- ☐ Maintain a low-profile presence to make it challenging for attackers to identify the firewall product and network topology.

22. ACK Bit Monitoring:

- ☐ Monitor ACK bits to allow only response to incoming packets, not initiation of new connections.

23. Continued Availability of Firewalls:

- ☐ Implement a hot standby for the primary firewall to ensure uninterrupted service.

24. Port Restrictions:

- ☐ Apply port restrictions and block specific ports that are not required for normal operation, reducing the attack surface.

20. Reporting Firewall Specific Incidents

There isn't a specific framework dedicated solely to reporting incidents in firewalls, but here are some key considerations for reporting firewall-specific incidents:

1. **Incident Identification:** Clearly define the incident, and determine whether it relates to the firewall. Incidents could include unauthorized access attempts, firewall misconfigurations, or the detection of malicious traffic.
2. **Documentation:** Document all relevant details about the incident, including timestamps, affected systems, IP addresses, and any firewall logs or alerts.
3. **Incident Classification:** Categorize the incident based on its severity, impact, and potential consequences. This classification can help in determining the appropriate response.
4. **Reporting:** Notify your organisation's incident response team, security officers, and relevant stakeholders about the incident. Reporting should be done promptly to initiate a coordinated response.
5. **Containment and Mitigation:** While not specific to reporting, the incident response process should include steps to contain and mitigate the incident, which might involve adjusting firewall rules, blocking traffic, or taking other protective measures.
6. **Notification:** In certain situations, particularly those involving data breaches or compliance requirements, legal or regulatory entities may need to be notified.
7. **Post-Incident Analysis:** After the incident is resolved, conduct a post-incident analysis to understand the root cause, lessons learned, and ways to improve firewall configurations and incident response procedures.

21. Reporting Firewall Specific Incidents

Firewall configurations can vary depending on the firewall type and technology in use, be it hardware or software-based. Nevertheless, adhering to best practices is essential to maximise the firewall's effectiveness in safeguarding your network.

SANS Institute recommends blocking outbound traffic on the following ports to enhance security:

- MS RPC TCP, UDP Port 135
- NetBIOS/IP TCP, UDP Port 137-139
- SMB/IP TCP Port 445
- Trivial File Transfer Protocol (TFTP) UDP Port 69
- System log UDP Port 514
- Simple Network Management Protocol (SNMP) UDP Port 161-162
- Internet Relay Chat (IRC) TCP Port 6660-6669

References

1. **NIST Guidelines on Firewalls and Firewall Policy**
 - Source: National Institute of Standards and Technology (NIST)
 - URL: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-41r1.pdf>
2. **Centre for Internet Security (CIS) Benchmarks**
 - Source: Centre for Internet Security (CIS)
 - URL: <https://downloads.cisecurity.org/#/>